Entrega 3 · Documento 4

Propuesta de controles de seguridad

Confidencialidad, autenticidad e integridad de la información

Sistema integrado de eventos laborales (JML)

Andina Servicios S.A.S. (empresa ficticia · datos ficticios)

Politécnico Grancolombiano · Gerencia de Proyectos en Seguridad de la Información · Grupo D01

24 de octubre de 2026

Todas las pruebas se ejecutaron contra el despliegue local del sistema (BunkerWeb + aplicación + PostgreSQL + GLPI 11 + MariaDB en Docker Compose). No se ejecutaron pruebas activas contra servicios de terceros (Supabase). Los secretos y tokens de las evidencias están enmascarados.

1. Propósito y enfoque

Este documento describe la arquitectura de seguridad del Sistema integrado de eventos laborales y propone el conjunto de controles que protegen las tres propiedades de la información exigidas: confidencialidad, autenticidad e integridad. Los controles no son aspiracionales: cada uno está implementado y verificado por las pruebas de los Documentos 1 a 3, que se citan como evidencia. El enfoque es de defensa en profundidad y seguridad por diseño, guiado por el modelo de amenazas STRIDE del SRS (amenazas T1 a T21).

El sistema gestiona eventos laborales (ingreso, retiro, emergencia, etc.) y genera tickets para TI en GLPI. Maneja datos personales de colaboradores y campos especialmente sensibles (el motivo de un retiro, la descripción de una emergencia), lo que hace de la confidencialidad y la trazabilidad requisitos centrales, no accesorios.

2. Arquitectura de seguridad (defensa en profundidad)

El sistema se organiza en capas concéntricas. Todo acceso externo cruza un único borde (el WAF BunkerWeb) por TLS; detrás, la aplicación aplica autorización por rol y aísla los campos restringidos; el worker es el único componente que habla con GLPI; y los datos viven en Supabase (con TLS, MFA y RLS) y en GLPI/MariaDB. Ningún servicio distinto del WAF publica puertos al exterior.

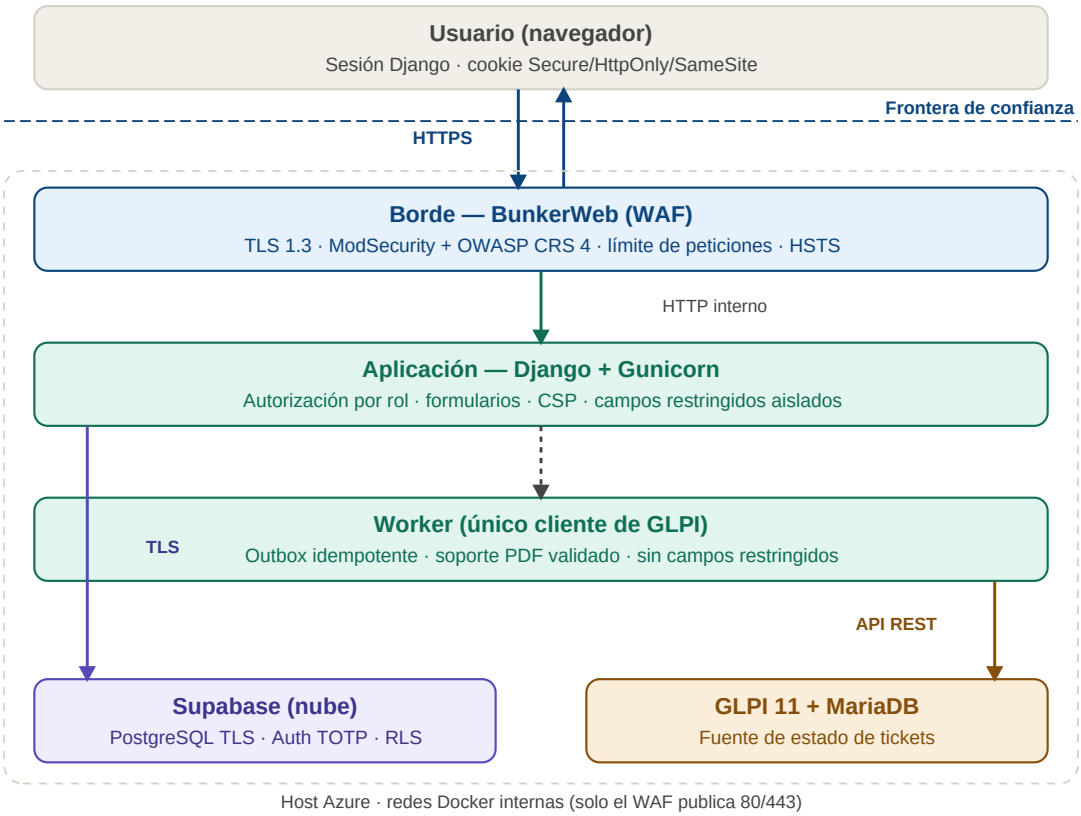

Figura 1. Arquitectura en capas y frontera de confianza. El tráfico externo entra solo por el WAF (TLS); los tramos internos viven en redes Docker aisladas. Verificado en los Documentos 2 (nmap, TLS) y 3 (captura de tráfico).

3. Los controles por propiedad

El siguiente esquema resume los controles principales agrupados por la propiedad que protegen. Las secciones 4 a 6 los detallan con su evidencia.

Figura 2. Controles de confidencialidad, autenticidad e integridad. Cada bloque se detalla con su mecanismo y su evidencia en las secciones siguientes.

4. Confidencialidad

Objetivo: que cada dato sea visible solo para quien debe verlo, en tránsito y en reposo, con atención especial a los campos restringidos.

Control	Mecanismo	Amenaza	Evidencia
TLS en el borde	BunkerWeb termina TLS 1.2/1.3; HTTP→HTTPS; HSTS	T19	Doc 2 §4; Doc 3 §4
Campos restringidos aislados	Motivo/descripción solo en solicitud_restringida; fuera de GLPI, logs, dashboard y fichas	T7	Doc 1 CU-07/09; Doc 3 §5
Autorización por rol	Cada vista verifica el rol; 403/404 según el caso	T10	Doc 1 CU-10; Doc 2 ZAP
Aislamiento de la base	Esquema app no expuesto; RLS; sin GRANT a anon/authenticated	T8	Doc 2 §6
Logs sin secretos	Filtro de password, token, totp, secret, motivo, descripcion	T7, T9	Doc 1 suite; Doc 3 §6
service_role acotado	Solo en el contenedor admin-usuarios	T14	Doc 2 §6; compose

La prueba más contundente de confidencialidad es el seguimiento de los valores centinela (Documento 3 §5): el motivo de un retiro viaja cifrado fuera del host, se almacena en PostgreSQL y **nunca llega a GLPI** (0 tramas), cumpliendo el invariante 5 del sistema.

5. Autenticidad

Objetivo: garantizar que quien actúa es quien dice ser y que tiene permiso para hacerlo, y que ninguna acción sensible ocurre con una sola firma.

Control	Mecanismo	Amenaza	Evidencia
Autenticación fuerte (AAL2)	Supabase Auth: contraseña + TOTP; la sesión de Django solo se crea tras el 2.º factor	T1	Doc 1 §2; suite Supabase 8/8
Registro cerrado	Sin registro abierto; cuentas solo por comando de administración	T15	SRS RF-06; estado
Sesión endurecida	Cookie Secure/HttpOnly/SameSite; rotación de id; 30 min / 8 h	T1	Doc 3 §6
Autorización por rol	Roles leídos de la base en cada petición; incompatibilidades	T15	Doc 1 CU-10; Doc 3 §7
Doble firma	El solicitante y RRHH firman; RRHH no se autoaprueba	T15	SRS §3.3; Doc 1 CU-05
Credenciales de servicio	Tokens de GLPI sin acceso a la interfaz; API de GLPI cerrada en el borde	T2	Doc 2 §3; auditoría
Límite de intentos	5/min en ingreso y TOTP; baneo por mal comportamiento; error genérico	T1	Doc 2 §5.3; Doc 1

6. Integridad

Objetivo: que los datos no se alteren de forma no autorizada y que toda acción quede registrada de manera verificable e irrepudiable.

Control	Mecanismo	Amenaza	Evidencia
Auditoría encadenada	hash = SHA-256(hash_anterior ■ contenido); ancla diaria a Blob inmutable	T6	Doc 1 CU-11; dominio
Solicitud inmutable	Disparador en la base bloquea modificar una solicitud aprobada	T3	Doc 2 §6 (prueba negativa)
Auditoría solo inserción	REVOKE de UPDATE/DELETE a app_backend sobre auditoría y afines	T6	Doc 2 §6
Deduplicación en la base	Restricción parcial única; el código solo traduce el error	T13	Doc 1 CU-03
Anti-inyección	ORM parametrizado; cabeceras como input no confiable; WAF (CRS)	T4	Doc 2 §5.2; Doc 3 §7
Cuentas derivadas	El estado de una cuenta solo lo cambia la sincronización de tickets resueltos	T5	SRS §4.7; escenarios
Soporte validado	PDF por firma de contenido y tamaño; nombre aleatorio; volumen noexec	T17	Doc 1 CU-06; SRS RF-39

La integridad de la auditoría se demostró de dos formas: la vista del Auditor verifica la cadena íntegra (Doc 1 CU-11) y la base rechaza, en motor, tanto la modificación de la auditoría como la de una solicitud aprobada (Doc 2 §6, pruebas negativas dentro de transacciones revertidas).

7. Hallazgos abiertos y recomendaciones

Las pruebas no revelaron defectos explotables. Los hallazgos abiertos son de severidad media o inferior; se consolidan aquí con su acción recomendada.

Id	Hallazgo	Sev.	Acción recomendada
V-01	Imágenes base con CVE de SO	Media	Cadencia de refresco de digest + Trivy programado
V-03	API interna del WAF visible en red app	Baja	Revisar API_WHITELIST_IP; separar interfaz de red
V-04	Endurecimiento de MariaDB	Baja	Desactivar local_infile; TLS en GLPI↔MariaDB
C-01	Tokens de GLPI en claro (tramo interno)	Baja	TLS/mTLS worker↔GLPI si el modelo lo exige
V-02 / C-02	Cabeceras en 302; BD local sin TLS	Baja/Inf.	Opcional; no aplica a producción (Supabase TLS)

Pendiente de la fase de despliegue (Azure): completar las pruebas dinámicas (ZAP y sqlmap) contra el entorno real con la IP del escáner fuera del baneo, y ejecutar el respaldo y la restauración con evidencia (RS-13, CA-11).

8. Conclusión

La arquitectura protege las tres propiedades de la información con controles implementados y verificados: TLS y aislamiento de campos restringidos para la confidencialidad; autenticación de dos factores, autorización por rol y doble firma para la autenticidad; y auditoría encadenada, inmutabilidad en la base y consultas parametrizadas para la integridad. La defensa en profundidad hace que el compromiso de una capa no baste para vulnerar el sistema. Los hallazgos abiertos son de mantenimiento y endurecimiento, y se atienden sin cambios de arquitectura.